

Policy Analysis: Sample Security Policy

Task 0 — Policy Analysis

Sample Policy Reviewed

SECURITY POLICY

All employees should use good passwords. Don't share them.
IT will handle security stuff.
Report problems to someone.
Updated: Sometime last year

Part A: Missing Components

Missing Component	Why It's Important
Header / Document Control (Policy ID, Version, Effective Date, Review Date, Owner, Approver, Classification)	Without version control and ownership data, no one can tell if they're reading the current policy, who is accountable for it, or when it's due for review. This creates confusion during audits and makes the document impossible to track over time.
Purpose statement	Readers need to understand <i>why</i> the policy exists and what risk it addresses. Without this, staff can't judge how to apply the rules to situations the policy doesn't explicitly cover.
Scope definition	It's unclear who must comply (employees only? contractors? vendors?) and what systems/assets are covered. This ambiguity lets people assume the policy doesn't apply to them.

Specific, measurable policy statements	"Use good passwords" is not actionable. There's no minimum length, complexity rule, rotation schedule, or MFA requirement, so compliance can't be verified or enforced.
Roles and responsibilities	"IT will handle security stuff" assigns no real accountability. A policy needs to specify who approves it, who implements controls, who monitors compliance, and what every employee is expected to do.
Enforcement section	There are no consequences defined for violations, so the policy has no teeth and cannot be consistently enforced.
Definitions	Terms like "good passwords" or "security stuff" are undefined, leaving them open to interpretation and inconsistent application.
Related documents / references	No links to supporting standards (e.g., an authentication standard, an incident response plan), so the policy exists in isolation rather than as part of a coherent governance framework.
Review/revision history	"Sometime last year" is not a real date. Without formal revision history, there's no way to confirm the policy has been reviewed, updated, or approved on any defined cadence.
Reporting/monitoring/auditing mechanism	"Report problems to someone" gives no contact, method, or process, so incidents are unlikely to be reported consistently or at all.
Exception process	There's no way to request or document a legitimate exception (e.g., a service account that can't use standard MFA), which pushes people toward silent non-compliance.

Acknowledgment mechanism	There's no way to confirm employees have read and agreed to the policy, which weakens its enforceability and audit defensibility.
--------------------------	---

Part B: Weaknesses

Weakness (Quote)	Problem	Impact
"All employees should use good passwords."	"Good" is subjective and unmeasurable — no minimum length, complexity, or standard (e.g., NIST 800-63B) is referenced.	Employees will interpret this differently; weak passwords (e.g., "Password1") could technically be considered "good" by some, leaving accounts vulnerable to brute-force and credential-stuffing attacks.
"Don't share them."	States the rule but gives no guidance on related risks — password managers, service/shared accounts, temporary access, or what to do if a password is compromised.	Employees may still write passwords down, reuse them across systems, or share them informally for convenience, since the policy offers no safer alternative or explanation of the risk.
"IT will handle security stuff."	Vague, informal language that doesn't specify what IT actually does (e.g., enforce complexity via system controls, monitor for breaches, reset compromised credentials).	Accountability is unclear; if a breach occurs, no one can be held responsible because no specific duty was ever assigned.
"Report problems to someone."	No named contact, email, ticketing system, or escalation path is provided.	Employees who notice suspicious activity likely won't report it, or reports will go to the wrong person, delaying incident response and increasing damage.

"Updated: Sometime last year"	Not a real date, and there's no version number, review cycle, or approver listed.	The policy can't be trusted as current, can't pass an audit, and there's no accountability for keeping it up to date.
No enforcement or consequences stated	The policy doesn't say what happens if someone violates it.	Without stated consequences, the policy is effectively optional, undermining compliance and legal defensibility if disciplinary action is ever needed.
No scope statement	It's unclear if contractors, vendors, or third parties must comply.	Non-employee users of company systems may operate with weak or shared passwords entirely outside the policy's reach, creating a security gap.

Part C: Rewritten Policy

Password Policy

Document Control

Field	Value
Policy ID	POL-SEC-001
Version	1.0
Effective Date	2026-08-19
Review Date	2027-08-19
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Executive Management
Classification	Internal

1. Purpose

This policy establishes requirements for creating, protecting, and managing passwords used to access company systems, applications, and data. Its purpose is to reduce the risk of unauthorized access resulting from weak, reused, shared, or compromised credentials, and to protect company information assets, customer data, and business operations from credential-based attacks such as brute-force, credential-stuffing, and phishing.

2. Scope

2.1 Applicability

This policy applies to:

- ☒ All employees
- ☒ Contractors and consultants
- ☒ Third-party vendors with access to company systems
- ☒ Interns and temporary staff

2.2 Systems/Assets Covered

This policy covers all company-owned or company-managed systems requiring authentication, including but not limited to: workstations and laptops, email accounts, cloud services (e.g., SaaS applications), internal applications, network infrastructure devices, databases, and any third-party system used to conduct company business.

2.3 Exclusions

This policy does not apply to publicly available, non-authenticated systems or to personal accounts unrelated to company business. Service accounts and system accounts are covered under a separate Privileged Access Management Standard, referenced in Section 9.

3. Policy Statements

3.1 Password Construction

All passwords used to access company systems must meet minimum strength requirements to resist guessing and automated attacks.

Requirements:

- Minimum length of 12 characters for standard user accounts and 16 characters for privileged/administrative accounts
- Passwords must not consist solely of common dictionary words, keyboard patterns (e.g., "qwerty123"), or easily guessed personal information (e.g., name, birthdate)
- Passwords must be unique to each system and must not be reused across company and personal accounts
- Multi-factor authentication (MFA) must be enabled on all systems that support it, in addition to a password

3.2 Password Protection and Handling

Passwords must be protected as confidential information at all times.

Requirements:

- Passwords must never be shared with another person, including coworkers, managers, or IT staff
- Passwords must never be written down in plain text or stored in unencrypted files, emails, or messages
- Employees must use the company-approved password manager to store and generate passwords
- Any suspected compromise of a password must be reported immediately per Section 5.2

3.3 Password Changes and Expiration

Passwords must be changed under defined circumstances to limit the window of exposure from a compromised credential.

Requirements:

- Passwords must be changed immediately if compromise is suspected or confirmed
- Default or vendor-supplied passwords must be changed before a system is put into use
- Accounts must be configured to lock after 5 consecutive failed login attempts, with unlock requiring identity verification through the IT Service Desk

4. Roles and Responsibilities

Role	Responsibilities
------	------------------

Executive Management	Approve this policy, allocate resources for its implementation, and demonstrate visible commitment to security practices
IT Security Team	Configure and enforce technical password controls (length, complexity, lockout, MFA), monitor for compromised credentials, and respond to reported incidents
Department Managers	Ensure their teams understand and comply with this policy and support required training
All Employees, Contractors, and Vendors	Create passwords that meet the requirements in Section 3, protect their credentials, use the approved password manager, and report suspected compromises promptly
Help Desk / IT Service Desk	Verify identity before resetting passwords or unlocking accounts, and log all reset requests

5. Compliance

5.1 Monitoring

The IT Security Team will use automated tools to monitor password compliance, including enforcement of complexity and length rules at the system level, and will periodically check for credentials exposed in known data breaches.

5.2 Reporting

Suspected password compromise, phishing attempts, or policy violations must be reported immediately to the IT Security Team at andrei@cyberdlh.lu or via the IT Service Desk ticketing system. Reports may be made anonymously if preferred.

5.3 Auditing

Compliance with this policy will be audited at least annually by the IT Security Team or an independent auditor, with findings reported to Executive Management.

6. Enforcement

6.1 Violations

Violations of this policy may result in:

- Verbal warning

- Written warning
- Suspension of system access privileges
- Disciplinary action up to and including termination
- Legal action where applicable, particularly in cases involving data breaches caused by policy violations

6.2 Reporting Violations

Report suspected violations to the IT Security Team at andrei@cyberdlh.lu or via the IT Service Desk.

7. Exceptions

7.1 Exception Process

Exceptions to this policy require:

1. A written request submitted to the CISO
2. A documented business justification
3. A risk assessment conducted by the IT Security Team
4. Compensating controls where applicable (e.g., additional monitoring)
5. Formal written approval and documentation retained by the IT Security Team

7.2 Exception Duration

All exceptions must have a defined end date and be reviewed quarterly until resolved or formally extended.

8. Definitions

Term	Definition
Password	A confidential string of characters used to verify a user's identity when accessing a system
Multi-Factor Authentication (MFA)	An authentication method requiring two or more independent verification factors (e.g., a password plus a one-time code)
Password Manager	A company-approved software tool used to generate, store, and autofill strong, unique passwords

Privileged Account	An account with elevated permissions, such as administrative or system-level access
Credential Compromise	Any event in which a password or authentication credential is disclosed to, or obtained by, an unauthorized party

9. Related Documents

- Information Security Policy
- Privileged Access Management Standard
- Acceptable Use Policy
- Incident Response Plan
- NIST Special Publication 800-63B (Digital Identity Guidelines)

10. Revision History

Version	Date	Author	Description
1.0	2026-08-19	CISO	Initial release, replacing informal password guidance

11. Acknowledgment

By accessing company systems, all users acknowledge they have read, understood, and agree to comply with this policy.

For formal acknowledgment tracking, use the company's policy acknowledgment system.

End of Policy Document